

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Calificación de las 23 Métricas DREAD bajo los 9 Criterios de Calidad

Kit GQM+PRAGMATIC • Edición 2025-2026 • España

"Medir la calidad de una métrica con otra métrica: esto es lo que los filósofos de la ciencia llaman metimetría, y lo que los CISOs experimentados llaman 'aprender de los errores ajenos antes de cometer los propios'."

GUÍA DE PUNTUACIÓN PRAGMATIC

Cada criterio se puntúa de **0 a 10** según la escala:

Puntuación	Significado
9-10	Criterio plenamente satisfecho; sin reservas
7-8	Criterio bien satisfecho; mejoras menores posibles
5-6	Criterio parcialmente satisfecho; requiere atención
3-4	Criterio débilmente satisfecho; mejora prioritaria
0-2	Criterio no satisfecho; revisar la métrica

Umbral de decisión sobre la métrica:

- **>= 72** (80%+): Métrica de élite — adoptar sin reservas
- **63-71** (70-79%): Alta calidad — adoptar con monitorización
- **45-62** (50-69%): Calidad media — adoptar con mejoras
- **< 45** (<50%): Baja calidad — revisar o descartar

EVALUACIÓN POR DIMENSIÓN DREAD

DIMENSIÓN D — DAÑO

D.M1 — ALE por amenaza crítica

Criterio	Descripción aplicada	Punt.
P Predictivo	Predice el coste financiero futuro con base en frecuencia histórica. Alta capacidad para planificación presupuestaria.	8
R Relevante	Alineado con ON-1, DORA Art.6 y el apetito de riesgo del Consejo. Extremadamente relevante para decisiones de inversión.	9
A Accionable	Genera decisiones concretas: ajustar controles, renegociar seguros cyber, revisar BCP. El €/año tiene traducción directa a presupuesto.	9
G Genuino	Puede manipularse si ARO o SLE se estiman sin datos históricos sólidos. Requiere auditabilidad de estimaciones.	6
M Significativo	Completamente comprensible para el CFO y la alta dirección. "Pérdida esperada anual de X euros" es el lenguaje de los negocios.	10
A Preciso	La precisión depende de la calidad de los datos históricos. Con datos reales: alta. Sin ellos: estimación gruesa.	6
T Oportuno	Cálculo trimestral adecuado para ciclos de planificación. Requiere actualización tras incidentes mayores.	7
I Independiente	Relativamente independiente. Cierta correlación con D.M4 (TBNO).	7
C Rentable	Coste moderado si existe CMDB y registros históricos. ROI muy alto: justifica inversiones millonarias con horas de análisis.	8
TOTAL		70
Nivel	ALTA — Adoptar con monitorización. Validar ARO/SLE con datos históricos mínimo 3 años. Usar metodología FAIR para mayor rigor.	★★★★☆

D.M2 — Índice de Exposición de Activos Críticos (IEAC)

Criterio	Descripción aplicada	Punt.
P Predictivo	Indica blast radius potencial; predice impacto operativo si se compromete el sistema crítico.	7
R Relevante	Directamente relevante para ENS (inventario activos) y NIS2 Art.21.2.f. Alta relevancia para CISO y arquitecto.	8
A Accionable	Genera acciones concretas de segmentación y micro-segmentación. % elevado = "microsegmentar ahora".	8
G Genuino	Depende de la calidad del CMDB. Si el inventario está desactualizado, la métrica engaña con datos aparentemente precisos.	5
M Significativo	"El 40% de nuestros activos críticos quedarían comprometidos" es comprensible para la dirección.	8
A Preciso	Alta precisión si el CMDB es correcto. En la práctica, la mayoría de las organizaciones tienen CMDB incompleto.	5
T Oportuno	Disponible mensualmente. Actualizable en tiempo real con herramientas BAS/ASM.	7
I Independiente	Alta independencia: no correlaciona directamente con otras métricas del set.	8
C Rentable	Coste moderado si el CMDB existe. Coste alto si hay que construirlo desde cero.	6
TOTAL		62
Nivel	MEDIA — Adoptar con mejoras: priorizar actualización del CMDB como condición previa.	★★★★☆☆

D.M3 — RTO realista vs. RTO objetivo (RTO gap)

Criterio	Descripción aplicada	Punt.
P Predictivo	Predice la capacidad real de recuperación ante incidente de máxima severidad.	9
R Relevante	Altamente relevante para DORA Art.11, NIS2 Art.21.2.c. KPI de primer nivel para operadores esenciales.	9
A Accionable	Gap positivo = invertir en capacidad de recuperación (backups, failover, DRP actualizado). Acción directa y clara.	9
G Genuino	Los ejercicios BCP/DRP pueden ser "ensayados". La genuinidad aumenta con ejercicios sorpresa o red team.	6
M Significativo	"Tardamos 6 horas más de lo permitido en recuperar el servicio" es perfectamente comprensible para el Consejo.	9
A Preciso	Alta precisión si los ejercicios son realistas. Baja si los escenarios son artificialmente favorables.	7
T Oportuno	Semestral adecuado para ciclos de planificación. Puede ser insuficiente con cambios frecuentes de arquitectura.	7
I Independiente	Independiente del resto de métricas DREAD. Mide recuperación, no prevención.	9
C Rentable	Los ejercicios BCP tienen coste significativo pero el ROI de conocer el gap es muy alto.	7
TOTAL		72
Nivel	ÉLITE — Adoptar sin reservas. Indispensable para DORA y NIS2.	★★★★★

D.M4 — Tasa de Brechas con Notificación Obligatoria (TBNO)

Criterio	Descripción aplicada	Punt.
P Predictivo	Mide el pasado inmediato. TBNO creciente predice mayor presión regulatoria.	6
R Relevante	Muy relevante para DPO, GDPR Art.33-34 y el registro del DPO.	8
A Accionable	TBNO alta = revisar arquitectura de datos y controles de acceso.	7
G Genuino	Riesgo de infra-reporte si hay incentivos para clasificar incidentes como no notificables.	5
M Significativo	Comprensible para DPO, asesoría legal y auditoría.	7
A Preciso	Depende de criterios claros de clasificación. Alta variabilidad interpretativa.	6
T Oportuno	Mensual es adecuado.	7
I Independiente	Relativamente independiente. Correlaciona con D.M1 en algunos casos.	7
C Rentable	Muy bajo coste: datos del registro DPO ya obligatorio por GDPR.	9
TOTAL		62
Nivel	MEDIA — Adoptar; mejorar criterios de clasificación de incidentes con datos personales.	★★★☆☆

D.M5 — Tiempo medio de clasificación DREAD-D (TMCD)

Criterio	Descripción aplicada	Punt.
P Predictivo	TMCD largo predice clasificaciones tardías que retrasan la respuesta a incidentes.	7
R Relevante	Directamente relevante para el proceso de gestión de amenazas y NIS2 Art.23 (alerta 24h).	8
A Accionable	TMCD > 24h = revisar proceso de triage, automatizar clasificación inicial, formar al equipo.	8
G Genuino	Fácil de medir objetivamente desde timestamps del ITSM. Alta genuinidad.	9
M Significativo	Comprensible para CISO y directores de operaciones.	7
A Preciso	Alta precisión si el ITSM registra timestamps con exactitud.	8
T Oportuno	Disponible en tiempo casi real desde el ITSM.	9
I Independiente	Alta independencia del resto de métricas.	8
C Rentable	Muy bajo coste: dato extraído automáticamente del ITSM existente.	9
TOTAL		73
Nivel	ÉLITE — Adoptar sin reservas. Métrica operativa de coste marginal nulo.	★★★★★

DIMENSIÓN R — REPRODUCIBILIDAD

R.M1 — MTTR por criticidad DREAD-R

Criterio	Descripción aplicada	Punt.
P Predictivo	MTTR elevado predice que los sistemas permanecerán expuestos a exploits el tiempo suficiente para ser comprometidos.	9
R Relevante	El KPI más relevante de la gestión de vulnerabilidades. Ligado a ENS Med.5 y CRA Art.13.	9
A Accionable	MTTR > umbral = escalar prioridad, asignar más recursos de parcheo, revisar el SLA del proceso VM.	9
G Genuino	Los timestamps de parcheo son objetivos y verificables. Difícil manipular sin dejar rastro.	8
M Significativo	"Tardamos 15 días en parchear una vulnerabilidad con exploit público" habla por sí solo a todos los niveles.	9
A Preciso	Alta precisión si la VM tool registra fechas de publicación CVE y de aplicación del parche.	8
T Oportuno	Disponible mensualmente de forma automática desde la VM tool.	8
I Independiente	Alta independencia. El MTTR mide velocidad de remediación, diferente a otras métricas.	8
C Rentable	Disponible desde herramientas VM ya desplegadas. Coste marginal muy bajo.	9
TOTAL		77
Nivel	ÉLITE — Métrica de referencia obligatoria. Benchmark universal del sector.	★★★★★

R.M2 — Tasa de Vulnerabilidades EPSS-alto sin Remediar (TVER)

Criterio	Descripción aplicada	Punt.
P Predictivo	EPSS es por definición predictivo (probabilidad empírica de explotación). TVER supera a CVSS en 33× (AUPRC 0.365 vs 0.011).	10
R Relevante	Más relevante que CVSS puro para priorización real: identifica las que los atacantes están explotando actualmente.	9
A Accionable	TVER > 20% = movilización urgente del equipo de parcheo con criterio de priorización claro.	9
G Genuino	EPSS score de FIRST.org es un modelo ML externo e independiente. Difícilmente manipulable internamente.	9
M Significativo	"El 15% de nuestras vulnerabilidades tienen alta probabilidad de explotación en 30 días y no están parchadas" es un mensaje potente.	8
A Preciso	EPSS v3 tiene alta precisión empírica validada con datos reales.	8
T Oportuno	EPSS se actualiza diariamente. TVER calculable semanalmente vía API.	9
I Independiente	Alta independencia. No correlaciona directamente con MTTR ni SMEC.	8
C Rentable	API EPSS de FIRST.org es gratuita. Coste de integración mínimo.	8
TOTAL		78
Nivel	ÉLITE MÁXIMA — La métrica predictiva más valiosa del kit. Adoptar de inmediato.	★★★★★

R.M3 — Índice de Cobertura de Exploits Públicos (ICEP)

Criterio	Descripción aplicada	Punt.
P Predictivo	Indica la "biblioteca de ataques disponibles". Un ICEP alto predice ataques más probables.	7
R Relevante	Complementa R.M2 con perspectiva de disponibilidad de toolkits de ataque.	7
A Accionable	Cada exploit público identificado = candidato inmediato para parcheo o mitigación compensatoria.	8
G Genuino	Datos de ExploitDB y Metasploit son bases públicas verificables. Alta genuinidad.	8
M Significativo	"El 30% de nuestras amenazas tienen exploit listo para usar en Metasploit" es impactante y comprensible.	8
A Preciso	Depende de mantener el registro DREAD actualizado.	6
T Oportuno	Verificación mensual puede ser tardía para exploits de día cero.	6
I Independiente	Correlaciona con R.M2 (los CVEs con exploits públicos suelen tener EPSS alto). Cierta redundancia.	6
C Rentable	Bases ExploitDB y Metasploit son gratuitas. La automatización del matching requiere desarrollo inicial.	7
TOTAL		63
Nivel	ALTA — Adoptar; considerar automatizar la verificación diaria vía API.	★★★★☆

R.M4 — Ventana de Exposición a Exploit (VEE)

Criterio	Descripción aplicada	Punt.
P Predictivo	VEE larga predice alta probabilidad de compromiso antes del parcheo.	8
R Relevante	Mide el problema central de la reproducibilidad: el tiempo de ventaja del atacante.	9
A Accionable	VEE > umbral = revisar proceso de detección/parcheo; implementar controles compensatorios.	8
G Genuino	Combinación de timestamps verificables (NVD + VM tool). Alta genuinidad.	8
M Significativo	"Tardamos 45 días en detectar una vulnerabilidad con exploit público en nuestra infraestructura" es impactante.	9
A Preciso	Alta precisión: ambas fechas son objetivas y verificables.	8
T Oportuno	Calculable por incidente en tiempo real. Tendencia mensual es oportuna.	8
I Independiente	Alta independencia. Mide el gap temporal, distinto a la tasa de remediación (R.M1).	8
C Rentable	Bajo coste si la VM tool y el SIEM registran los timestamps necesarios.	8
TOTAL		74
Nivel	ÉLITE — Adoptar sin reservas. Perspectiva de ventana temporal única.	★★★★★

DIMENSIÓN E — EXPLOTABILIDAD

E.M1 — Score medio de explotabilidad CVSS v4.0 (SMEC)

Criterio	Descripción aplicada	Punt.
P Predictivo	CVSS mide severidad técnica, no probabilidad de explotación. Valor predictivo muy limitado (AUPRC 0.011).	4
R Relevante	Relevante como medida de severidad técnica y para comparación con benchmarks del sector.	7
A Accionable	Genera priorización de parcheo, aunque subóptima sin EPSS. SMEC > 7.5 = movilizar recursos VM.	7
G Genuino	CVSS scores son públicos y provienen del NVD. Alta genuinidad del dato.	9
M Significativo	Comprensible para equipos técnicos. Requiere contexto para la alta dirección.	7
A Preciso	Técnicamente preciso para severidad. No preciso para probabilidad de explotación real.	6
T Oportuno	Disponible vía API NVD en tiempo real para cada CVE.	9
I Independiente	Metodológicamente independiente de EPSS. Mide dimensiones distintas aunque correlacionadas.	7
C Rentable	Coste prácticamente nulo: API pública del NVD gratuita.	10
TOTAL		66
Nivel	ALTA — Adoptar como métrica de severidad técnica. NO usar como predictor de explotación real (usar EPSS/KEV para ello).	★★★★☆

E.M2 — Tasa de Coincidencia con CISA KEV (TCKEV) ★ #1 DEL KIT

Criterio	Descripción aplicada	Punt.
P Predictivo	Vulnerabilidades en KEV = explotadas activamente AHORA. TCKEV > 0% predice compromiso inminente sin acción.	9
R Relevante	Extremadamente relevante: KEV = "lista de las más buscadas" del mundo cyber. Máxima relevancia operativa.	10
A Accionable	Cualquier CVE en KEV activo en la organización = prioridad máxima absoluta de parcheo. Accionabilidad binaria y urgente.	10
G Genuino	KEV es lista oficial del gobierno de EEUU (CISA). Máxima autoridad y credibilidad. Imposible de manipular.	10
M Significativo	"Tenemos 3 vulnerabilidades que el gobierno de EEUU certifica que están siendo explotadas por hackers ahora mismo" = máximo impacto posible.	10
A Preciso	Alta precisión: el matching CVE-KEV es un join exacto entre dos bases de datos estructuradas.	9
T Oportuno	KEV se actualiza diariamente. TCKEV calculable diariamente de forma automatizada.	9
I Independiente	Complementario pero no redundante con EPSS. KEV valida explotación real; EPSS predice futura.	8
C Rentable	KEV gratuito, API JSON pública. Coste de integración mínimo.	10
TOTAL		85
Nivel	ÉLITE ABSOLUTA — La métrica de mejor calidad PRAGMATIC del kit completo. Adoptar de inmediato.	★★★★★

E.M3 — Score DREAD-E para ataques sobre IA/LLMs

Criterio	Descripción aplicada	Punt.
P Predictivo	Vector LLM de crecimiento más rápido en 2025-2026 (Zahid et al., U.Waikato). Alta capacidad predictiva emergente.	8
R Relevante	Muy relevante para organizaciones con sistemas de IA en producción. Relevancia creciente con adopción de IA generativa.	8
A Accionable	E_LLM > 7 = implementar controles IA security (validación de prompts, guardrails, monitoring de outputs).	8
G Genuino	Requiere red team especializado en LLMs. Sin red team, la métrica es estimativa y potencialmente sesgada.	5
M Significativo	Comprensible para equipos técnicos de IA y seguridad. Requiere contexto para dirección no técnica.	6
A Preciso	Metodologías de evaluación de seguridad IA todavía madurando (OWASP LLM Top 10 v2025).	6
T Oportuno	Red team LLM es ejercicio periódico (trimestral/semestral), no continuo.	5
I Independiente	Altamente independiente: cubre vector de ataque emergente no capturado por métricas tradicionales.	9
C Rentable	Requiere expertise especializado. Coste inicial significativo pero el coste del no-hacerlo puede ser muy elevado.	5
TOTAL		60
Nivel	MEDIA — Adoptar para org. con IA en producción. Invertir en capacidad red team LLM.	★★★☆☆

E.M4 — Tiempo medio de contención de explotación (TMCE)

Criterio	Descripción aplicada	Punt.
P Predictivo	TMCE histórico bajo predice buenos resultados en próximos incidentes. Valor predictivo operativo.	7
R Relevante	Muy relevante para SOC/CIRT y cumplimiento DORA Art.19 y NIS2 Art.23.	9
A Accionable	TMCE > 1h = revisar playbooks, automatizar respuestas SOAR, mejorar capacidad SOC.	9
G Genuino	Timestamps del SIEM/SOAR son objetivos. Alta genuinidad.	9
M Significativo	"Tardamos 3 horas en contener el último exploit detectado" es comprensible y relevante para operaciones.	8
A Preciso	Alta precisión: dato de sistema con timestamps auditables.	9
T Oportuno	Disponible en tiempo real desde el SIEM. Muy oportuno.	9
I Independiente	Alta independencia. Mide velocidad de respuesta, no severidad ni probabilidad.	8
C Rentable	Extracción automática del SIEM/SOAR ya desplegado. Coste marginal prácticamente nulo.	9
TOTAL		77
Nivel	ÉLITE — Métrica operativa de primer nivel. Disponible en tiempo real.	★★★★★

E.M5 — Índice de Cobertura de Controles Anti-Explotación (ICCAE)

Criterio	Descripción aplicada	Punt.
P Predictivo	Cobertura alta de controles predice mayor resistencia a la explotación. Relación predictiva razonable.	7
R Relevante	Relevante para auditoría, ENS, NIS2 Art.21.2.g y seguimiento del roadmap de mejora.	8
A Accionable	ICCAE < 80% = identificar activos sin cobertura y priorizar su protección.	8
G Genuino	Depende de inventario completo y de que los controles estén realmente activos y correctamente configurados.	5
M Significativo	"Solo el 65% de nuestros sistemas tienen MFA activo" es comprensible a todos los niveles.	8
A Preciso	La precisión depende de la granularidad del inventario y de cómo se definen los controles activos.	6
T Oportuno	Actualizable mensualmente. Con CSPM puede ser continuo.	7
I Independiente	Independiente de las métricas de vulnerabilidad. Mide la capa de control, no el vector de ataque.	8
C Rentable	Moderado: requiere herramientas de gestión de configuración o revisión manual periódica.	6
TOTAL		63
Nivel	ALTA — Adoptar con inversión en automatización de gestión de configuración (CSPM).	★★★★☆

DIMENSIÓN A — USUARIOS AFECTADOS

A.M1 — Usuarios Máximos Potencialmente Afectados (UMPA)

Criterio	Descripción aplicada	Punt.
P Predictivo	Define el escenario de peor caso para el impacto ciudadano. Alta capacidad para modelar escenarios NIS2.	8
R Relevante	Máximamente relevante para operadores de servicios esenciales ante NIS2 Art.23.3 (umbral "gran magnitud").	9
A Accionable	UMPA > 50.000 = activar protocolo de notificación CNCS; diseñar planes de contingencia escalados.	9
G Genuino	Dato estructural del negocio (base de usuarios). Alta genuinidad si la base está actualizada.	8
M Significativo	"En caso de incidente en nuestro sistema X, 2,3 millones de ciudadanos quedarían sin servicio" = alto impacto para el Consejo.	10
A Preciso	Alta precisión si la base de usuarios/clientes está actualizada.	7
T Oportuno	Actualizable semestralmente. Suficiente para un dato estructural.	7
I Independiente	Alta independencia: mide escala de impacto potencial, no severidad técnica.	8
C Rentable	Bajo coste: dato del CRM/base de usuarios ya existente.	9
TOTAL		75
Nivel	ÉLITE — Indispensable para operadores de servicios esenciales.	★★★★★

A.M2 — Índice de Usuarios Vulnerables Afectados (IUVA)

Criterio	Descripción aplicada	Punt.
P Predictivo	Indica si un incidente podría desencadenar obligaciones reforzadas GDPR Art.9 y mayor escrutinio regulatorio.	7
R Relevante	Muy relevante para hospitales, servicios sociales, plataformas de menores y cualquier org. con datos GDPR Art.9.	8
A Accionable	IUVA > 30% = priorizar protección de esos servicios y datos; revisar medidas Art.32 GDPR.	7
G Genuino	Requiere clasificación de usuarios por categoría de datos. Difícil sin arquitectura de datos clara.	5
M Significativo	Comprensible para DPO y equipos legales. Requiere contexto para equipos técnicos.	7
A Preciso	Depende de la granularidad de la clasificación de datos GDPR Art.9.	5
T Oportuno	Revisión anual suficiente para un dato estructural.	6
I Independiente	Alta independencia del resto de métricas del set.	8
C Rentable	Requiere trabajo de clasificación de datos (Art.9 mapping) que puede tener coste significativo si no existe.	5
TOTAL		58
Nivel	MEDIA — Adoptar para org. con datos de categoría especial (hospitales, menores). Invertir en data classification.	★★★☆☆

A.M3 — Tiempo medio de notificación a usuarios (TMNU)

Criterio	Descripción aplicada	Punt.
P Predictivo	Mide eficacia pasada. Predice cumplimiento futuro de obligaciones GDPR Art.34.	7
R Relevante	Muy relevante para DPO, asesoría legal y GDPR Art.33-34. Relevancia regulatoria muy alta.	9
A Accionable	TMNU > 72h = revisar proceso de detección y escalado al DPO; activar procedimiento de notificación acelerada.	9
G Genuino	Timestamps verificables del DPO y del registro de incidentes. Alta genuinidad.	8
M Significativo	"Tardamos 5 días en notificar a los usuarios cuando el límite es 30 días" es comprensible para todos.	8
A Preciso	Alta precisión: timestamp con referencia regulatoria clara (72h AEPD; 30 días para afectados).	9
T Oportuno	Calculable por incidente en tiempo real.	9
I Independiente	Alta independencia. Mide el proceso de comunicación, no el impacto técnico.	8
C Rentable	Coste prácticamente nulo si el registro DPO está en orden (ya obligatorio por GDPR).	9
TOTAL		76
Nivel	ÉLITE — Obligatoria para cumplimiento GDPR. Adoptar sin reservas.	★★★★★

A.M4 — Coste por Usuario Afectado (CUA)

Criterio	Descripción aplicada	Punt.
P Predictivo	CUA histórico alto predice coste total elevado en futuros incidentes con alto número de afectados.	7
R Relevante	Relevante para el CFO, el Consejo y los seguros cyber. Traduce el impacto en ratio por usuario.	8
A Accionable	CUA > benchmark sectorial = revisar eficiencia del proceso de respuesta; reducir el blast radius.	7
G Genuino	Requiere contabilización completa del coste total. Tendencia a subestimar costes indirectos y reputacionales.	5
M Significativo	"Cada usuario afectado nos costó 340 euros en el último incidente" es un mensaje financiero muy potente.	9
A Preciso	Moderada: la contabilización completa puede tomar meses.	5
T Oportuno	El dato real está disponible semanas/meses después del incidente. Limitada oportunidad.	5
I Independiente	Correlaciona con D.M1 (ALE) pero desde perspectiva por usuario.	6
C Rentable	Requiere proceso formal de contabilización post-incidente. Coste significativo si no existe.	5
TOTAL		57
Nivel	MEDIA — Útil para benchmarking y seguros cyber. Implementar proceso de contabilización post-incidente.	★★★☆☆

A.M5 — Cobertura de Continuidad para Usuarios Críticos (CCUC)

Criterio	Descripción aplicada	Punt.
P Predictivo	Cobertura alta del BCP predice mayor resiliencia y menor impacto en usuarios durante un incidente.	8
R Relevante	Muy relevante para operadores esenciales NIS2 y DORA Art.11 (continuidad del negocio TIC).	9
A Accionable	CCUC < 99% en esenciales = identificar usuarios no cubiertos y ampliar el BCP.	8
G Genuino	La "cobertura BCP" puede ser teórica si los planes no se han testado. Requiere validación mediante ejercicios.	5
M Significativo	"Solo el 72% de nuestros usuarios críticos tienen plan de continuidad activo" es comprensible y preocupante.	8
A Preciso	Moderada: la definición de "cubierto por BCP" puede ser ambigua sin criterios claros.	6
T Oportuno	Revisión semestral (post-ejercicio BCP). Suficiente.	7
I Independiente	Alta independencia del resto del set. Mide preparación estructural, no riesgo técnico.	8
C Rentable	El BCP ya es obligatorio (NIS2, DORA). Medir la cobertura no añade coste significativo.	8
TOTAL		67
Nivel	ALTA — Adoptar; validar cobertura con ejercicios reales periódicos.	★★★★☆

DIMENSIÓN Disc — DESCUBRIBILIDAD

Disc.M1 — Ratio de Superficie de Ataque Expuesta (RSAE)

Criterio	Descripción aplicada	Punt.
P Predictivo	RSAE alto predice mayor probabilidad de descubrimiento y explotación por atacantes externos.	9
R Relevante	Directamente relevante para gestión de la superficie de ataque, CRA Art.13 y NIS2 Art.21.2.e.	9
A Accionable	RSAE > 15% = revisar firewall rules, retirar servicios innecesarios, implementar ASM continuo.	9
G Genuino	Las herramientas ASM/Shodan/Censys miden la realidad objetiva del espacio internet.	9
M Significativo	"El 8% de nuestra infraestructura es visible desde internet sin credenciales" es comprensible y alarmante.	9
A Preciso	Alta precisión si las herramientas ASM tienen cobertura completa del espacio de IPs de la organización.	8
T Oportuno	Disponible semanalmente de forma automatizada. Muy oportuno.	9
I Independiente	Alta independencia del resto de métricas. Perspectiva del atacante.	8
C Rentable	Shodan/Censys tienen versiones gratuitas o de muy bajo coste. ROI excelente.	8
TOTAL		78
Nivel	ÉLITE MÁXIMA — Métrica de perspectiva del atacante insustituible. Adoptar con ASM continuo.	★★★★★

Disc.M2 — Ratio de Detección Proactiva vs. Reactiva (RDPR)

Criterio	Descripción aplicada	Punt.
P Predictivo	RDPR bajo predice que la organización continuará siendo sorprendida. Alta relevancia predictiva estratégica.	8
R Relevante	Mide el aspecto más estratégico de la descubribilidad: ¿quién descubre antes, nosotros o el atacante?	9
A Accionable	RDPR < 50% = invertir en threat hunting proactivo, red team, bug bounty program.	8
G Genuino	La clasificación de detecciones como "proactivas" o "reactivas" puede ser subjetiva. Requiere criterios claros.	6
M Significativo	"En el 60% de los casos, el atacante descubrió la vulnerabilidad antes que nosotros" = mensaje impactante.	9
A Preciso	Moderada: la línea entre proactivo y reactivo no siempre es clara.	6
T Oportuno	Trimestral adecuado para el ciclo de reporting.	7
I Independiente	Alta independencia. Perspectiva de ventaja relativa respecto al atacante.	8
C Rentable	Requiere registro sistemático del origen de descubrimiento de cada vulnerabilidad. Coste moderado.	6
TOTAL		67
Nivel	ALTA — Adoptar; establecer criterios claros de clasificación proactivo/reactivo.	★★★★☆

Disc.M3 — Número de Servicios Innecesarios Expuestos (NSIE)

Criterio	Descripción aplicada	Punt.
P Predictivo	NSIE alto predice mayor superficie de ataque y más vectores de entrada potenciales.	8
R Relevante	Muy relevante para la higiene de la superficie de ataque y el principio de mínimo privilegio de red.	8
A Accionable	Cada servicio innecesario detectado = acción inmediata de desactivación o documentación de justificación.	9
G Genuino	El escáner de puertos mide la realidad objetiva. La clasificación "innecesario" requiere validación.	7
M Significativo	"Tenemos 15 puertos abiertos en activos críticos que no deberían estar activos" = mensaje claro y urgente.	8
A Preciso	Alta precisión para el conteo. La clasificación "innecesario" requiere proceso de validación.	7
T Oportuno	Mensual adecuado. Con automatización puede ser semanal.	8
I Independiente	Relacionado con Disc.M1 pero más granular y operacional. Cierta redundancia conceptual.	6
C Rentable	Escáneres de puertos gratuitos (Nmap, Masscan). Coste marginal muy bajo.	9
TOTAL		70
Nivel	ALTA — Adoptar; automatizar con escáner ASM continuo o CSPM.	★★★★☆

Disc.M4 — Tiempo Medio de Detección Externa (TMDE)

Criterio	Descripción aplicada	Punt.
P Predictivo	TMDE largo predice ventanas de exposición amplias ante nuevas vulnerabilidades.	8
R Relevante	Captura el aspecto más relevante de la descubribilidad: tiempo de ventaja del atacante antes de que nos enteremos.	9
A Accionable	TMDE > 7 días = implementar monitorización ASM continua; suscribirse a alertas tempranas INCIBE-CERT/CVE.	9
G Genuino	Requiere datos de ASM externas y NVD. El dato es objetivamente verificable.	8
M Significativo	"Tardamos 12 días en darnos cuenta de que éramos visibles con esa vulnerabilidad" = altamente impactante.	9
A Preciso	Alta precisión si los timestamps están bien registrados en ASM y SIEM.	7
T Oportuno	Calculable por incidente/evento. Tendencia mensual oportuna.	7
I Independiente	Relacionado conceptualmente con R.M4 (VEE) pero desde perspectiva externa. Complementario, no redundante.	7
C Rentable	Requiere herramienta ASM con timestamps históricos. Coste moderado pero ROI muy alto.	7
TOTAL		71
Nivel	ALTA — Adoptar con herramienta ASM que soporte timestamps históricos.	★★★★☆

TABLA RESUMEN: RANKING PRAGMATIC COMPLETO DE LAS 23 MÉTRICAS DREAD

Rk	Métrica	Dim	P	R	A	G	M	A	T	I	C	Total	Nivel
1	E.M 2 — TCK EV	E	9	10	10	10	10	9	9	8	10	85	★★ ★★ ★ ÉLITE ABSOLUTA
2	R.M 2 — TVE R	R	10	9	9	9	8	8	9	8	8	78	★★ ★★ ★ ÉLITE MÁXIMA
3	Disc. M1 — RSA E	Disc	9	9	9	9	9	8	9	8	8	78	★★ ★★ ★ ÉLITE MÁXIMA
4	R.M 1 — MTT R	R	9	9	9	8	9	8	8	8	9	77	★★ ★★ ★ ÉLITE
5	E.M 4 — TMC E	E	7	9	9	9	8	9	9	8	9	77	★★ ★★ ★ ÉLITE
6	A.M 3 — TM NU	A	7	9	9	8	8	9	9	8	9	76	★★ ★★ ★ ÉLITE
7	A.M1 — UM PA	A	8	9	9	8	10	7	7	8	9	75	★★ ★★ ★ ÉLITE

8	R.M 4 — VEE	R	8	9	8	8	9	8	8	8	8	74	★★ ★★ ★ ÉLIT E
9	D.M 5 — TMC D	D	7	8	8	9	7	8	9	8	9	73	★★ ★★ ★ ÉLIT E
10	D.M 3 — RTO gap	D	9	9	9	6	9	7	7	9	7	72	★★ ★★ ★ ÉLIT E
11	Disc. M4 — TM DE	Disc	8	9	9	8	9	7	7	7	7	71	★★ ★★ ★ ALT A
12	D.M 1 — ALE	D	8	9	9	6	10	6	7	7	8	70	★★ ★★ ★ ALT A
13	Disc. M3 — NSIE	Disc	8	8	9	7	8	7	8	6	9	70	★★ ★★ ★ ALT A
14	A.M 5 — CCU C	A	8	9	8	5	8	6	7	8	8	67	★★ ★★ ★ ALT A
15	Disc. M2 — RDP R	Disc	8	9	8	6	9	6	7	8	6	67	★★ ★★ ★ ALT A
16	E.M1 — SME C	E	4	7	7	9	7	6	9	7	10	66	★★ ★★ ★ ALT A
17	E.M 5 — ICCA E	E	7	8	8	5	8	6	7	8	6	63	★★ ★★ ★ ALT A

18	R.M 3 — ICEP	R	7	7	8	8	8	6	6	6	7	63	★★ ★★ ALT A
19	D.M 2 — IEAC	D	7	8	8	5	8	5	7	8	6	62	★★ ★☆ MED IA
20	D.M 4 — TBN O	D	6	8	7	5	7	6	7	7	9	62	★★ ★☆ MED IA
21	E.M 3 — DRE AD- E LLM	E	8	8	8	5	6	6	5	9	5	60	★★ ★☆ MED IA
22	A.M 2 — IUV A	A	7	8	7	5	7	5	6	8	5	58	★★ ★☆ MED IA
23	A.M 4 — CUA	A	7	8	7	5	9	5	5	6	5	57	★★ ★☆ MED IA

ANÁLISIS DE PATRONES PRAGMATIC EN EL SET DREAD

Patrón 1: La Genuinidad (G) es el talón de Aquiles sistémico

Las métricas que puntúan más bajo en G comparten una causa raíz: dependencia de inventarios de activos incompletos (CMDB) o de estimaciones subjetivas. **Recomendación sistémica:** Invertir en automatización (CSPM, VM automatizado, ASM, SIEM) para elevar el criterio G en todo el set de forma transversal.

Patrón 2: Las métricas en tiempo real dominan el ranking

Las 10 métricas de mayor puntuación PRAGMATIC son calculables de forma automática o semi-automática desde sistemas ya desplegados (SIEM, VM tool, ITSM, API pública). Los criterios T (Oportuno) y C (Rentable) son los mejor valorados consistentemente.

Patrón 3: CISA KEV demuestra el poder de las fuentes autoritativas externas

E.M2 (TCKEV) obtiene la puntuación absoluta más alta (85/90) porque combina máxima relevancia operativa con máxima autoridad de la fuente (gobierno USA) y coste prácticamente nulo. Es el ejemplo perfecto del criterio PRAGMATIC en acción.

Patrón 4: La dimensión A (Usuarios Afectados) tiene la mayor varianza interna

UMPA (75) y TMNU (76) son de élite, mientras que IUVA (58) y CUA (57) son de calidad media. Esto refleja que medir la **escala** de usuarios es simple (dato del CRM), pero medir la **calidad** del impacto por tipo de usuario es significativamente más complejo y costoso.

Recomendación de implementación por prioridad

Fase 1 — Coste casi nulo (implementar en < 30 días):

E.M2 (TCKEV), D.M5 (TMCD), R.M2 (TVER), A.M3 (TMNU), E.M4 (TMCE), R.M1 (MTTR)

Fase 2 — Inversión moderada (implementar en 3–6 meses):

Disc.M1 (RSAE), R.M4 (VEE), A.M1 (UMPA), D.M3 (RTO gap), Disc.M4 (TMDE)

Fase 3 — Inversión estratégica (implementar en 6–12 meses):

D.M1 (ALE con FAIR), D.M2 (IEAC con CMDB actualizado), E.M3 (DREAD-E LLM)

Matriz PRAGMATIC · Documento B del Kit GQM+PRAGMATIC DREAD · Abril 2026

Basado en: Brotby & Hinson (2013), securitymetametrics.com, INCIBE-IMC, FIRST EPSS, CISA KEV